



GDPR för AI studenter

– En introduktion

Magnus.Witting@iths.se



IT-HÖGSKOLAN

Här startar din IT-karriär.

Syftet med dagen är att deltagarna skall:

1. Känna till grundläggande begrepp och principer i GDPR
2. Ha en förståelse för de viktigaste reglerna och hur de skall tillämpas av personuppgiftsansvarig
3. Fått svar på egna frågor



Rätten till personlig integritet är en grundläggande mänsklig rättighet

Den är inskriven i regeringsformen 2:6 och i Europakonventionen om skydd för de mänskliga rättigheterna

Dataskyddsförordningen detaljerar individens rättigheter och hur de skall säkerställas

DSO skall övervaka att den personuppgiftsansvarige säkerställer dessa rättigheter



IT-HÖGSKOLAN

Här startar din IT-karriär.

Vad är en personuppgift?

- En personuppgift är all information som direkt eller indirekt kan användas för att identifiera en fysisk person
- Exempel på personuppgifter är: namn, efternamn, personnummer, adress, telefonnummer, e-postadress, bild, IP-adress, inloggningsuppgifter, registreringsnummer, fingeravtryck, position, bankkortsnummer
- En kombination av uppgifter som var för sig inte är personuppgifter

Har ni testat? Hur visar ni hur ni testat?



Vad är personuppgiftsbehandling?

Personuppgiftsbehandling är **ALLT** man kan göra med en personuppgift

- Exempelvis: ta emot, samla in, lagra, vidarebefordra, läsa, blockera, skriva ut, uppdatera, komplettera, flytta, radera...OCH säkerhetslagra
- Tänk på att er organisation lagrar personuppgifter som inte är synliga i de vanliga användargränssnitt det gäller loggar, backupper, användarregister etc.

Vad är en känslig personuppgift?

Utgångspunkten är att det är **förbjudet** att behandla känsliga personuppgifter, Ni måste säkerställa att ni har undantag från förbudet

- Benämns som *särskild kategori* i lagtexten
- En känslig personuppgift är en uppgift som avslöjar:
 - ras eller etniskt ursprung
 - politiska åsikter
 - religiös eller filosofisk övertygelse
 - medlemskap i fackförening
 - hälsoaspekter
 - en persons sexualliv eller sexuell läggning
 - genetiska uppgifter
 - biometriska uppgifter som entydigt identifierar en person
 - lagöverträdelse som innefattar brott



Personuppgifter -känsligare än vi tror



<https://www.youtube.com/watch?v=CAMoPbj3jQE>

Stora mängder anonyma digitaliserade personuppgifter

- Dina Facebook likes
- Ditt foto
- Dina resvanor

+ Lärande maskiner

= Mönsterigenkänning

= Kategorisering

= Precis marknadsföring och propaganda

= Diskriminering

! Massor av skandaler

Hur gör vi med Foton?

- Foton är biometriska uppgifter och därför känsliga
- Men... ”endast definieras som biometriska uppgifter när de behandlas med särskild teknik som möjliggör identifiering eller autentisering av en fysisk person.” S 51
- De kräver därför skyddsåtgärder, som om de vore känsliga personuppgifter
- Var extremt restriktiv med att publicera dem



<https://www.theguardian.com/lifeandstyle/2022/nov/18/can-anyone-avoid-cctv-surveillance-we-ask-an-expert>

Foton för vissa användningar

- Är bilderna ett resultat av ett konstnärligt skapande eller
- har ett journalistiskt ändamål gäller inte GDPR

Men om samma bilder skulle börja användas i till exempel kommersiella sammanhang, då kan GDPR gälla och det behövs en laglig grund för behandlingen

[Lag \(1978:800\) om namn och bild i reklam](#)



Särskilda personuppgifter

Personnummer och samordningsnummer utgör inte känsliga personuppgifter i dataskyddsförordningens mening, men har ändå getts en särställning genom att medlemsstaterna getts möjlighet att införa särskilda villkor för behandlingen (artikel 87).

10 § Personnummer och samordningsnummer får behandlas utan samtycke endast när det är klart motiverat med hänsyn till ändamålet med behandlingen, vikten av en säker identifiering eller något annat beaktansvärt skäl.

OBS Engelsk text i lagstiftningen ”or any other identifier of general application”

Det är rimligt att anta att även fastighetsbeteckning, anläggnings ID mm är att betrakta som särskilda personuppgifter

Personuppgiftsansvarig

- Juridisk person, offentlig myndighet, institution eller annat organ som ensamt eller tillsammans med andra **bestämmer ändamålen** med behandlingen av personuppgifter
- Man kan vara gemensamt personuppgiftsansvarig (§26) om:
 - Det rör sig om leverans av professionella tjänster
 - Samverkan kring gemensamma system
- Är den som ansvarar gentemot den registrerade och myndigheter
- Ny vägledning om gränsdragningen mellan ansvarig och biträde
https://edpb.europa.eu/system/files/2021-07/eppb_guidelines_202007_controllerprocessor_final_en.pdf

Personuppgiftsbiträde §28

- Den som behandlar personuppgifter för den personuppgiftsansvariges räkning är personuppgiftsbiträde.
- Skall bara behandla PU i enlighet med **instruktionerna**.
- Konsulter som jobbar i PUAs organisation är normalt inte biträden.
- Har eget ansvar för personuppgiftsbehandlingen
- Skriftligt medgivande för att anlita underbiträden
- Har ett eget ansvar för att vidta lämpliga tekniska och organisatoriska åtgärder för att se till att säkerhetsnivån för er behandling är tillräcklig
- Skall informera personuppgiftsansvarig om personuppgiftsincidenter

Personuppgiftsincident §§ 33,34 skäl 85-88

- En personuppgiftsincident är en säkerhetsincident som leder till:
 - oavsiktlig eller olaglig förstöring, förlust eller ändring av personuppgifter som behandlas
 - obehörigt röjande av eller obehörig åtkomst till de behandlade personuppgifterna
- GDPR ställer krav på att rapportera till IMY inom 72 timmar (och i förekommande fall till de drabbade individerna) från vetskap om incidenten

PU ansvarig måste ha förmågan att upptäcka och kartlägga incidenter

- **Exempel:** diskriminering, identitetsstöld, bedrägeri, skadlig ryktesspridning, brott mot sekretess eller tystnadsplikt, personuppgifter har blivit förstörda, personuppgifter har kommit i orätta händer
- <https://www.datainspektionen.se/lagar--regler/Anmälan/personuppgiftsincident/anmala-personuppgiftsincident/>

Personuppgiftsincident - metoder



Monitorering

Vi behöver övervaka vad som händer i våra och biträdets system

Loggning

Vi skall kunna rapportera vad som hänt och kunna åtgärda

Rapporteringsrutiner

Hur och när skall biträdet rapportera?

Hur kopplar vi incidenten till vår krishantering?

Vem rapporterar till IMY och meddelar den registrerade?

Läsa och förstå Dataskyddsförordningen

1. **EUROPAPARLAMENTETS OCH RÅDETS FÖRORDNING (EU) 2016/679 av den 27 april 2016 (GDPR)** <https://eur-lex.europa.eu/legal-content/SV/TXT/PDF/?uri=CELEX:32016R0679&from=SV>
2. Innehåller 173 skäl utan egentlig struktur, använd (ctrl+F) för att söka nyckelord
3. Guidelines and opinions från EDPB lämnar riktlinjer i vissa frågor https://edpb.europa.eu/our-work-tools/our-documents/publication-type/guidelines_sv
4. Lag (2018:218) med kompletterande bestämmelser till EU:s dataskyddsförordning <https://lagen.nu/2018:218> Innehåller svenska avväganden om frivilliga delar av lagstiftningen
5. För tolkningar och förklaringar till delar av GDPR se lagens förarbeten se Riksdagen.se och Regeringen.se
6. Branschstandards eller rekommendationer från branschorgan

Har vi rättslig grund för
behandling av personuppgifter?





6 rättsliga grunder för behandling

Egentligen bara 4

1. Fullgörande av avtal

2. Rättslig förpliktelse

3. Skydda den registrerades intressen

4. Allmänt intresse

5. Interesseavvägning

6. Samtycke

Rättslig grund – Vissa är bättre än andra

- Man ska kunna påvisa hur beslut om personuppgiftsbehandling har tagits och att relevanta faktorer har beaktats och vilken grund man använder för varje behandling
- En rättslig grund är *samtycke* från den registrerade. Samtycke alltid kan återkallas vilket innebär att personuppgifterna inte längre får behandlas. Det är också svårt att i efterhand bevisa vad den registrerade har samtyckt till och att samtycket inte återtagits.
- Avtal och rättslig förpliktelse är de tydligaste grunderna för behandling och de som är mest praktiska att dokumentera och informera om.

Hur gör vi med bilder på anställda i reklam?

Samtycke skall vara:

1. Frivilligt
2. Specifikt
3. Otvetydigt
4. Individuellt
5. Informerat

Frågan om samtycke måste ställas fritt från andra frågor, på ett klart och lättbegripligt språk och separerat från andra villkor

Bekräftelse på samtycke måste vara en aktiv handling, inte förkryssade rutor, organisationen måste säkerställa att den kan bevisa att samtycke givits

Den registrerade kan när som helst ta tillbaka sitt samtycke, tex genom att ringa kundtjänst.

Totalt 5 825,70 SEK
Taxor, skatter och avgifter inräknat

Vara noga med att läsa igenom [flygbolagets prisvillkor](#) innan du slutför köpet

Jag samtycker till att, enligt p. 3. F. i [Privacy Policy](#), få mig tillsänt personliga erbjudanden relaterade till tjänster som tillhandahålls av lastminute.com-gruppen eller dess partners. Dessa erbjudanden skräddarsys via profilering och automatisk bearbetning av mina data för att vara mer relevanta för mig, och kan skickas till mig via post, e-post, SMS, telefon eller onlineannonser. ☐

Kryssa i denna ruta för att bekräfta att du läst, förstått och att du accepterar de [allmänna villkoren](#) samt [integritetspolicyn](#). Om du inte vill få våra nyhetsbrev, skriv till privacy.en@lastminutegroup.com. ☒

[Tillbaka](#)

Köp

Vad händer nu?

Leverantören kommer att bekräfta din biljett och sedan skickar vi ett bekräftelsemejl till dig med all information du behöver. Gör dig redo att resa!

Kan jag göra ändringar senare?

Ja! Ring oss för att lägga till tjänster eller göra ändringar i din bokning minst 24 timmar före avgång.

[Vill du ställa en annan fråga? Ring oss nu!](#)

Intresseavvägning § 6f skäl 47

En personuppgiftsansvarigs berättigade intressen, inklusive intressena för en personuppgiftsansvarig till vilken personuppgifter får lämnas ut, eller för en tredje part, kan utgöra rättslig grund för behandling, på villkor att de registrerades intressen eller grundläggande rättigheter och friheter inte väger tyngre, med beaktande av de registrerades rimliga förväntningar till följd av förhållandet till den personuppgiftsansvarige.

- Se tex SWEMA regler för direktmarknadsföring <https://www.swedma.se/>
- Får inte användas som laglig grund av myndigheter
- Om den registrerade invänder mot behandlingen är det klokt att avstå

Sätt dig själv i den registrerades ställning när du gör avvägningen



Följer vi de bärande
principerna?

De 6 bärande principerna

ÄNDAMÅLSBEGRÄNSNING

Personuppgifter får endast behandlas för specifika, explicita och legitima ändamål

LAGRINGSMINIMERING

Personuppgifter ska inte lagras längre än nödvändigt med hänsyn till ändamålet

UPPGIFTSMINIMERING

Personuppgifter som samlas in ska vara relevanta och begränsade till vad som är nödvändigt med hänsyn till ändamålet

LAGLIGHET, KORREKTHET & ÖPPENHET

Behandlingen ska vara laglig, rättvis och öppen i relation till individen

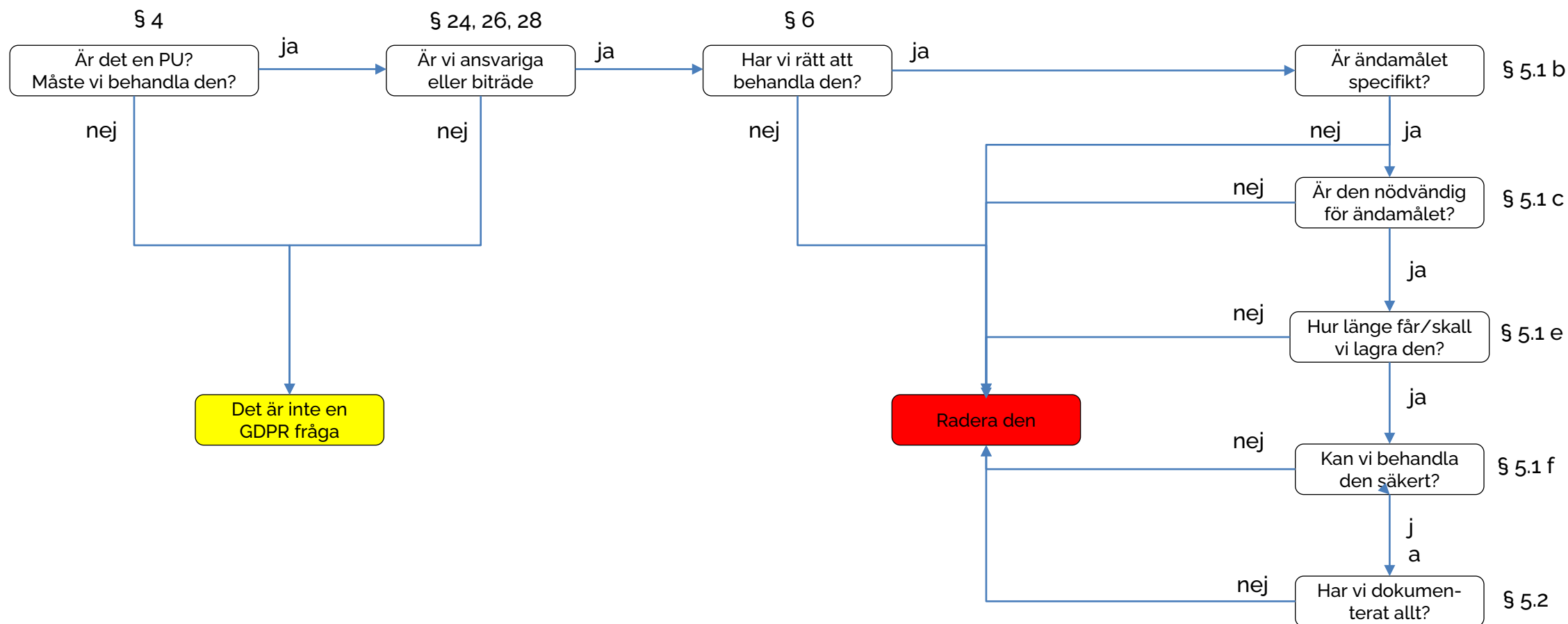
INTEGRITET & KONFIDENTIALITET

Alla lämpliga åtgärder ska tas till för att personuppgifter ska behandlas på ett säkert sätt

ANSVARSSKYLDIGHET

Om man behandlar personuppgifter besitter man ett ansvar och skyldighet att kunna demonstrera överensstämmelse med principerna

Beslutsträd för organisationer som omfattas av GDPR



Övning: Vilka uppgifter behöver vi i rekryteringsprocessen?

Vårt företag behöver rekrytera medarbetare. Vi tänker oss processen i flera steg.

I det första skall vi annonsera och be intresserade att skicka in information som behövs för att vi skall kunna välja ut 10 kandidater att gå vidare med

Vi förväntar oss ca 100 svar

Namn

Adress

E-postadress

Telefonnummer

Referenser

Personnummer

Personlig berättelse

Utbildning

Lämplighetsbedömning

Familjeförhållanden

Tidigare arbetsgivare

Utdrag ut brottsregister

Sjukdomshistorik

Civilstånd

Särskilda behov

Förmågor vi bör övervaka och testa

1. Att ha fullständig koll på alla personuppgifter som koncernen/myndigheten behandlar
2. Att kunna fastställa på vilken grund vi behandlar personuppgifter
3. Att säkerställa att alla personuppgifter är korrekta, aktuella och relevanta
4. Att kunna inhämta samtycke från alla som man samlar in personuppgifter om
5. Att kunna informera de registrerade om vad personuppgifterna ska användas till, vilken rätt man har att samla in och bearbeta uppgifterna och den registrerades rätt att ta tillbaka samtycket, att få sina uppgifter ändrade eller raderade och att lämna klagomål till IMY
6. Att kunna kontrollera Identitet och ålder på personer som hämtar eller lämnar personuppgifter



Har vi säkerställt den
registrerades rättigheter?

Metoder för att öka efterlevnaden av GDPR

1. Införande av sanktionsavgifter – Liknar konkurrenslagstiftningen (ICO)
2. Tydliggörande av grunden för rätten till skadestånd (Romregistret)
3. Personuppgifter har blivit en vara med tydligare äganderätt –så att de registrerade själva kan tillvarata sina rättigheter

-Vi behöver ha en bra dokumentation kring på vilka grunder vi behandlar PU

Meta fined more than \$400 million in Ireland over EU privacy breaches [cnb.cx/3IwcZWR](https://www.cnb.cx/3IwcZWR)

<https://www.voister.se/artikel/2022/03/klarna-far-7-5-miljoner-i-gdpr-boter/>

<https://www.svt.se/nyheter/lokalt/skane/alla-i-romregistret-far-ersattning-av-jk>

EU-kommissionen utdömde rekordböter på 2,9 miljarder euro för lastbilskartell

<https://www.svd.se/story/lastbilskartellen>

Den registrerades rättigheter

- **Rätt till information §§ 13-14**
 - Den registrerade har rätt att få information om när och hur dennes personuppgifter behandlas
- **Rätt till tillgång §15**
- **Rätt till rättelse §16 och radering (rätten att bli glömd) §17**
 - Den registrerade ska ha rätt att utan dröjsmål få felaktiga personuppgifter rättade
 - Den registrerade ska ha rätt att utan dröjsmål få sina personuppgifter raderade
 - Personuppgiftsansvarig skall underrätta mottagare om begäran §19
- **Rätt till begränsning §18**
 - Den registrerade har rätt att begränsa behandlingen av sina personuppgifter om exempelvis personuppgifterna anses vara inkorrekta eller om behandlingen är olaglig, eller säga nej till profilering eller för att den registrerade behöver uppgifterna
 - **OBS detta innebär att uppgifterna inte får raderas eller behandlas på något annat sätt än lagring**

Den registrerades rättigheter

- **Rätt till dataportabilitet §20**
 - Personuppgifter som lämnats av den registrerade och behandlas med stöd av avtal eller samtycke skall lämnas i maskinläsbart format på begäran av den registrerade
- **Rätt till invändningar §21**
 - Den registrerade kan invända mot behandling pga. Pga sin specifika situation
- **Rätt att invända mot profilering eller automatiserat beslutsfattande §22**
 - Den registrerade ska ha rätt att inte bli föremål för ett beslut som enbart grundas på automatiserad behandling, inbegripet profilering, om det har betydande påverkan
- **Rättigheterna kan begränsas med hänvisning till bland annat nationell säkerhet § 23**

Förmågor vi bör övervaka och testa

1. Att på begäran kunna ta fram personuppgifter som gäller en viss person
2. Att på begäran kunna radera alla personuppgifter om en viss person efter att först ha bedömt att det inte stöter på hinder
3. Att kunna ändra personuppgifter på begäran av den det gäller
4. Att, om man har överfört personuppgifter till annan organisation, säkerställa att ändring eller radering av personuppgifter överförs till den organisationen
5. Att kunna ta emot och hantera information från en annan organisation om ändringar och radering av personuppgifter
6. **Att kunna lämna ut alla uppgifter till en registrerad i maskinläsbart format utan onödigt krångel**

Sammanfattning

- Vi behöver visa att vi har kontroll på alla våra *behandlingar av Personuppgifter*
- Vi skall ha ett tydligt *ändamål* för alla våra behandlingar
- Behandlingarna skall uppfylla lagens principer
- Och ha en angiven laglig grund, i sista hand *samtycke*
- Kan vi säkerställa de *registrerades rättigheter*?

